# Title of the project :- Integrate Zscaler with Identity Providers (IdPs) such as Azure AD

## Overview:-

In modern organizations, employees access company resources from different locations, devices, and networks. This creates security challenges such as unauthorized access, identity theft, and data breaches. To address these issues, organizations use **Zero Trust security models**, where every user must be verified before accessing applications. One of the popular cloud security platforms used for this purpose is Zscaler.

This project focuses on integrating **Zscaler** with Identity Providers (IdPs) like **Microsoft Azure Active Directory** to enable secure authentication and centralized identity management. An Identity Provider (IdP) is a service that manages user identities and authentication, allowing users to log in once and securely access multiple applications.

Through this integration, users can authenticate using their **Azure AD credentials**, and Zscaler will verify the identity before allowing access to internet or enterprise applications. This process is usually implemented using authentication protocols such as **Security Assertion Markup Language (SAML)** or **OpenID Connect**, which allow secure communication between Zscaler and the identity provider.

By integrating Zscaler with Azure AD, organizations can implement **Single Sign-On (SSO)**, meaning users only need to log in once to access multiple services. This improves both **security and user experience**, while also allowing administrators to apply centralized access policies, monitor user activity, and quickly revoke access if a security risk is detected.

The main objective of this project is to design and implement a secure authentication framework where **Zscaler uses Azure AD as the identity provider**, ensuring that only authenticated and authorized users can access network resources. This integration strengthens network security, simplifies user management, and supports modern cloud-based enterprise environments.

Overall, the project demonstrates how cloud security platforms like **Zscaler** can work together with identity management systems such as **Azure AD** to create a **secure, scalable, and efficient access control system** for organizations.

**List of Teammates**

| S.NO | NAME | COLLEGE | CONTACT |
|---|---|---|---|
| 01 | AADHIL IRFAN A | Nandha Arts and Science College | iaadhil467@gmail.com |
| 02 | ANITHA K | Nandha Arts and Science College | anithaakumaresan@gmail.com |
| 03 | ARUN KARTHICK K | Nandha Arts and Science College | kumargeetha@gmail.com |
| 04 | ARUNKUMAR V | Nandha Arts and Science College | arunvadivel734@gmail.com |
| 05 | BHARATH BALAJI G | Nandha Arts and Science College | bharathgiri7755@gmail.com |

**List of Vulnerability Table**

| S.NO | Vulnerability Name | CWE/CVE - No |
|---|---|---|
| 01 | Broken Access Control | CWE-36 |
| 02 | Security Misconfiguration | CWE-11 |
| 03 | Software Supply Chain Failures | CWE-447 |
| 04 | Cryptographic Failure | CWE-261 |
| 05 | Injection | CWE-83 |
| 06 | Insecure Design | CWE-183 |

| | | |
|---|---|---|
| **07** | **Authentication Failures** | **CWE-259** |
| **08** | **Software or Data Integrity Failures** | **CWE-426** |
| **09** | **Security Logging & Alerting Failures** | **CWE-778** |
| **10** | **Mishandling of Exceptional Conditions** | **CWE-369** |

## Report:

### 1. Vulnerability name: Absolute Path Traversal

**CWE: 36**

**OWASP category**: **A01 Broken Access Control**

### Description

Absolute Path Traversal is a security vulnerability where an attacker is able to access files or directories on a server by manipulating file paths in an application. Normally, applications restrict users to access only specific folders or resources. However, due to improper validation of file paths, attackers may bypass these restrictions and directly request sensitive files stored on the system.

In this vulnerability, the attacker uses **absolute file paths** such as /etc/passwd, C:\Windows\system32\config, or other system paths to retrieve confidential information. The application fails to properly validate or sanitize the file path provided by the user, allowing unauthorized access to system files, configuration files, or application data.

In environments where security platforms like **Zscaler** are integrated with identity providers such as **Microsoft Azure Active Directory**, improper access control in web applications or APIs can allow attackers to exploit path traversal vulnerabilities to bypass authentication mechanisms and access protected resources.

This vulnerability occurs mainly due to:

- Improper input validation
- Lack of access control checks

- Insecure file handling mechanisms
- Poor implementation of security controls in the application

If not properly mitigated, attackers can gain access to sensitive system information, configuration files, and authentication credentials.

## Business Impact

Absolute Path Traversal vulnerabilities can have serious consequences for organizations, including:

**1. Data Breach**
Attackers may gain access to sensitive files such as user information, passwords, API keys, and database credentials, leading to confidential data exposure.

**2. Unauthorized Access to System Files**
Attackers can access critical system files stored on the server, which may reveal information about system structure, configuration settings, and internal directories.

**3. System Compromise**
Access to configuration files may allow attackers to understand the system architecture and exploit additional vulnerabilities, potentially leading to full system compromise.

**4. Loss of Customer Trust**
Exposure of sensitive information can damage the organization's reputation and reduce customer confidence in the company's ability to protect their data.

**5. Financial Loss**
Security breaches may lead to financial losses due to legal penalties, incident response costs, recovery expenses, and compensation to affected users.

**6. Compliance Violations**
Organizations handling sensitive data may violate security regulations such as the **General Data Protection Regulation (GDPR)** or the **Payment Card Industry Data Security Standard (PCI DSS)**, which may result in regulatory fines and legal consequences.

**7. Service Disruption**
Attackers may access or manipulate important application files, which can cause application malfunction, service downtime, or operational disruption.

## 2. Vulnerability name: ASP.NET Misconfiguration: Creating Debug Binary

**CWE: 11**

**OWASP category: A02 Security Misconfiguration**

## Description

ASP.NET Misconfiguration: Creating Debug Binary is a security vulnerability that occurs when an ASP.NET application is deployed with the debug mode enabled. In development environments, debug mode is used to help developers identify and fix errors by providing detailed debugging information. However, if this setting remains enabled in a production environment, it can expose sensitive system information.

When debug mode is enabled, the application may generate debug binaries and detailed error messages that reveal internal information about the application. This information may include source code paths, server details, stack traces, configuration settings, and other technical data.

Attackers can analyze this information to understand the structure of the application and identify additional vulnerabilities. This increases the risk of targeted attacks against the system.

This vulnerability usually occurs due to improper configuration in the web.config file of the ASP.NET application, where the debug attribute is set to true instead of false during deployment.

## Business Impact

ASP.NET Misconfiguration vulnerabilities can have serious consequences for organizations, including:

**1. Information Disclosure**
Debug mode may expose detailed error messages, stack traces, and system paths that reveal sensitive internal information about the application and server.

**2. Exposure of Application Structure**
Attackers may learn about the application architecture, file locations, and internal logic, making it easier to identify additional vulnerabilities.

**3. Increased Attack Surface**
The exposed debugging information can help attackers craft more precise and effective attacks against the application.

**4. Security Weakness Identification**

By analyzing debug information, attackers may discover other misconfigurations, insecure code practices, or system weaknesses that can be exploited.

**5. Reputational Damage**

Security vulnerabilities that expose internal system information can damage the organization's reputation and reduce user trust.

**6. Compliance Violations**

Organizations handling sensitive or regulated data may violate security compliance standards if such misconfigurations expose sensitive information.

**7. Potential System Exploitation**

Attackers may use the information obtained from debugging messages to perform further attacks such as code injection, unauthorized access, or privilege escalation.

## 3. Vulnerability name: Use of Obsolete Function

**CWE: 447**

**OWASP category**: **A03 Software Supply Chain Failures**

**Description**

Use of Obsolete Function is a security vulnerability that occurs when an application uses outdated or deprecated functions that are no longer considered secure. These functions may have known security weaknesses or may not follow modern security standards.

Obsolete functions are often replaced by newer and more secure alternatives by software vendors or programming frameworks. However, if developers continue using these outdated functions in the application code, it may expose the system to potential security risks.

In many cases, obsolete functions may lack proper security controls such as strong encryption, input validation, or secure authentication mechanisms. Attackers may exploit these weaknesses to bypass security protections or gain unauthorized access to the system.

This vulnerability usually occurs due to poor code maintenance, outdated libraries, or failure to update application dependencies regularly.

## Business Impact

The use of obsolete functions in applications can create several security and operational risks for organizations, including:

**1. Security Vulnerabilities**
Outdated functions may contain known security flaws that attackers can exploit to compromise the application.

**2. Increased Risk of Exploitation**
Attackers can use publicly known vulnerabilities associated with obsolete functions to perform attacks such as unauthorized access, data manipulation, or system compromise.

**3. System Instability**
Obsolete functions may not be compatible with modern software environments, leading to application errors, crashes, or unexpected behavior.

**4. Data Security Risks**
Weak or outdated security mechanisms may expose sensitive data such as user credentials, personal information, or confidential business data.

**5.Compliance Violations**
Organizations may fail to meet security compliance requirements if outdated and insecure functions are used in production systems.

**6. Maintenance Challenges**
Applications that rely on obsolete functions become harder to maintain and update, increasing development and operational costs.

**7. Reputational Damage**
Security incidents caused by outdated code can damage the organization's reputation and reduce customer trust in the organization's security practices.

## 4. Vulnerability name: **Weak Encoding for Password**

**CWE: 261**

**OWASP category: A04 Cryptographic Failures**

## Description

Weak Encoding for Password is a security vulnerability that occurs when an application stores or processes user passwords using weak encoding techniques instead of strong cryptographic methods. Encoding methods such as Base64 or simple reversible encoding are not designed to securely protect sensitive information like passwords.

When passwords are stored using weak encoding, attackers who gain access to the database or application files can easily decode the encoded passwords and retrieve the original values. This makes it easier for attackers to compromise user accounts and gain unauthorized access to the system.

Secure applications should use strong cryptographic techniques such as password hashing with secure algorithms and salting to protect user credentials. However, when weak encoding methods are used instead, the security of user authentication is significantly reduced.

This vulnerability usually occurs due to improper implementation of password storage mechanisms or lack of secure cryptographic practices during application development.

### Business Impact

Weak Encoding for Password vulnerabilities can have serious consequences for organizations, including:

**1. Credential Exposure**
Attackers may easily decode weakly encoded passwords and obtain user login credentials, leading to unauthorized account access.

**2. Account Compromise**
Once attackers obtain user credentials, they can log in as legitimate users and perform unauthorized actions within the system.

**3. Data Breach**
Compromised accounts may allow attackers to access sensitive personal or organizational data stored in the application.

**4. Privilege Escalation**
If administrative accounts are compromised, attackers may gain higher privileges and control over the application or system.

**5. Loss of Customer Trust**
Exposure of user credentials can damage the organization’s reputation and reduce customer confidence in its security practices.

**6. Financial Loss**

Organizations may face financial losses due to fraud, legal penalties, or the cost of incident response and system recovery.

**7. Compliance Violations**

Storing passwords using weak encoding methods may violate security regulations and standards, leading to regulatory penalties and legal consequences.

**5. Vulnerability name**: **Improper Neutralization of Script in Attributes in a Web Page**

**CWE: 261**

**OWASP category: A05 Injection**

## Description

Injection vulnerabilities occur when an application sends untrusted or malicious input to an interpreter as part of a command or query. The attacker manipulates the input data in such a way that it changes the intended command or query execution.

In this vulnerability, the application does not properly validate or sanitize user input before processing it. As a result, attackers can insert malicious code or commands that the system interprets and executes.

Injection attacks can occur in different forms such as SQL injection, command injection, or script injection. These attacks may allow attackers to access unauthorized data, modify system information, or execute malicious commands on the server.

This vulnerability mainly occurs due to improper input validation, insecure coding practices, and lack of secure data handling mechanisms in the application.

### Business Impact

Injection vulnerabilities can have serious consequences for organizations, including:

**1. Unauthorized Data Access**

Attackers may retrieve sensitive data such as customer records, login credentials, or confidential business information.

**2. Data Manipulation**

Attackers may modify or delete important data stored in the application database.

**3. System Compromise**

Injection attacks may allow attackers to execute system commands and gain control over the application server.

**4. Financial Loss**

Data breaches and system compromise may lead to financial penalties and recovery costs.

**5. Loss of Customer Trust**

Exposure or manipulation of sensitive information can damage the organization's reputation.

## 6. Vulnerability name： Permissive List of Allowed Inputs

**CWE: 183**

**OWASP category: A06 Insecure Design**

## Description

## Description

Insecure Design refers to security weaknesses that arise due to poor system architecture or flawed application design. This vulnerability occurs when security considerations are not properly included during the design phase of the software development lifecycle.

Even if the code is written correctly, an insecure system design may allow attackers to bypass security controls. Examples include missing authentication checks, improper access control mechanisms, or insecure data handling.

Insecure design issues often occur when threat modeling, risk assessment, or secure architecture planning is not performed during application development.

## Business Impact

Insecure design vulnerabilities can lead to major security risks for organizations, including:

**1. Weak Security Architecture**

Poor system design may create multiple entry points for attackers.

**2. Unauthorized Access**

Attackers may bypass security mechanisms and access restricted resources.

**3. Data Exposure**

Sensitive data may be exposed due to poor security design.

**4. Increased Security Risks**

Weak design increases the chances of multiple vulnerabilities within the system.

**5. Operational and Financial Impact**

Organizations may face financial losses and operational disruption due to security incidents.

## 7. Vulnerability Name: Use of Hard-coded Password

**CWE: 259**

**OWASP Category: A07 Authentication Failures**

## Description

Authentication failures occur when an application improperly implements authentication mechanisms that verify the identity of users. This vulnerability may allow attackers to bypass authentication controls and gain unauthorized access to the system.

Common causes of authentication failures include hard-coded credentials, weak password policies, insecure session management, and improper validation of user credentials.

When authentication mechanisms are not securely implemented, attackers may impersonate legitimate users and access sensitive information or system functions.

## Business Impact

Authentication failures can significantly affect organizational security, including:

**1. Unauthorized Account Access**

Attackers may gain access to user accounts without proper authentication.

**2. Account Takeover**

Attackers may impersonate legitimate users and perform malicious activities.

**3. Data Breach**

Unauthorized access may expose sensitive user and business data.

**4. Privilege Escalation**

Attackers may gain administrative access to the system.

**5. Reputational Damage**

Security incidents related to authentication failures can damage the organization’s credibility.

## 8. Vulnerability Name: Untrusted Search Path

**CWE: 426**

**OWASP Category: A08 Software or Data Integrity Failures**

## Description

Software or Data Integrity Failures occur when applications fail to verify the integrity of software updates, libraries, or critical data. This vulnerability allows attackers to modify or replace trusted software components with malicious versions.

For example, if applications download updates or external libraries without verifying their integrity or authenticity, attackers may inject malicious code into the system.

This vulnerability may occur due to insecure software update mechanisms, lack of digital signatures, or absence of proper integrity verification processes.

## Business Impact

Software or data integrity failures can cause serious security threats, including:

**1. Malicious Code Execution**
Attackers may inject malicious software into trusted applications.

**2. System Compromise**
Compromised software components may give attackers control over the system.

**3. Data Manipulation**
Attackers may alter critical data stored within the system.

**4. Supply Chain Attacks**
Compromised third-party libraries may introduce hidden vulnerabilities into the application.

**5. Operational Disruption**
Malicious software may disrupt system operations and services.

## 9. Vulnerability Name: Insufficient Logging

**CWE: 778**

**OWASP Category**: A09 **Security Logging & Alerting Failures**

## Description

Security Logging and Alerting Failures occur when applications do not properly record or monitor security-related events. Logging and monitoring are essential for detecting suspicious activities and responding to security incidents.

If an application fails to generate logs for important security events such as login attempts, configuration changes, or system errors, organizations may not detect attacks in time.

Without proper monitoring and alerting mechanisms, attackers may remain undetected in the system for long periods, increasing the severity of the attack.

## Business Impact

Security logging and alerting failures can create major operational and security risks, including:

**1. Delayed Detection of Attacks**
Organizations may fail to detect security breaches in a timely manner.

**2. Lack of Incident Response**
Without proper logs, it becomes difficult to investigate and respond to security incidents.

**3. Extended Attack Duration**
Attackers may remain in the system for a long time without detection.

**4. Compliance Issues**
Many regulatory standards require proper logging and monitoring of security events.

**5. Operational Risk**
Failure to monitor system activity increases the overall risk of cyber attacks.

## 10. Vulnerability Name: Divide By Zero

**CWE: 369**
**OWASP Category: A10  Mishandling of Exceptional Conditions**

## Description

Mishandling of Exceptional Conditions occurs when an application does not properly handle unexpected errors or exceptional situations during execution. Examples include division by zero errors, invalid inputs, or unexpected system failures.

If these exceptions are not handled properly, the application may crash or display detailed error messages that reveal internal system information.

Attackers may intentionally trigger these errors to gather information about the system, identify vulnerabilities, or disrupt the normal functioning of the application.

Proper exception handling mechanisms should be implemented to ensure that errors are managed securely without exposing sensitive information.

## Business Impact

Improper handling of exceptional conditions can affect organizations in several ways, including:

**1. Information Disclosure**

Detailed error messages may expose system paths, configuration details, or application logic.

**2. Application Crash**

Unhandled exceptions may cause the application to crash or become unavailable.

**3. Service Disruption**

Frequent errors may lead to service downtime and operational disruption.

**4. Security Exploitation**

Attackers may exploit errors to discover system weaknesses.

**5. Reputational Damage**

Frequent application failures may reduce user trust and damage the organization’s reputation.

## STAGE 2

## Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

**Target website :-** http://testfire.net/

**Target ip address:-** 65.61.137.117

**List of vulnerability:-**

| s.no | Vulnerability name | Severity | plugins |
|---|---|---|---|
| 1 | TLS Version 1.0 Protocol Detection | MEDIUM | 104743 |
| 2 | TLS Version 1.1 Protocol Deprecated | MEDIUM | 157288 |
| 3 | SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam) | LOW | 83875 |
| 4 | ICMP Timestamp Request Remote Date Disclosure | INFO | 10114 |
| 5 | Additional DNS Hostnames | INFO | 46180 |
| 6 | Apache Tomcat Detection | INFO | 39446 |
| 7 | Common Platform Enumeration (CPE) | INFO | 45590 |
| 8 | Device Type | INFO | 54615 |
| 9 | HSTS Missing From HTTPS Server | INFO | 84502 |
| 10 | HTTP Server Type and Version | INFO | 10107 |

## REPORT: -

**1) Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection**

**Severity: -** MEDIUM

**Plugin: -** 104743

**Port: -** 443

**Description: -** The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

**Solution: -** Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

**Business Impact: -**Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non-compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

**2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated**

**Severity: - MEDIUM**

**Plugin: -** 157288

**Port: -** 443

**Description:**

The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1 As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

**Solution: -** Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1

**Business Impact:**

The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

.

3) **Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)**
**Severity: - LOW**

**Plugin: -** 83875

**Port: -** 443

**Description:**

The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

**Solution: -** Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

**Business Impact:**

Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

**4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure**
**Severity: - INFO**

**Plugin: -** 10114

**Port: - 0**

**Description: -** The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.
Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

**Solution: -** Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

**Business Impact: -**This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

## 5) Vulnerability Name: - 46180 - Additional DNS Hostnames Severity: - INFO

**Plugin: -** 46180

**Port: - 0**

**Description: -** Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

**Solution: -** If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com [192.0.32.10]

**Business Impact: -**This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

### 6) Vulnerability Name: - 39446 - Apache Tomcat

### Detection Severity: - INFO

**Plugin: -** 39446

**Port: - 80**

**Description: -**Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

**Business Impact: -**Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

### 7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

**Severity: - INFO**

**Plugin: -** 45590

**Port: - 0**

**Description: -** By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

**Business Impact:**

This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

## 8) Vulnerability Name: - Device Type Severity: - INFO

**Plugin: -** 54615

**Port: - 0**

**Description: -** Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

**Business Impact:**

It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network management, optimization, and ensures that the right security measures are in place for each device typ

## 9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server Severity: - INFO

**Plugin: -** 84502

**Port:** - 443

**Description:**

The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL- stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

**Solution:** - Configure the remote web server to use HSTS**.**

**Business Impact:**

Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-the- middle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

## 10) Vulnerability Name: - 10107 - HTTP Server Type and Version Severity: - INFO

**Plugin: -** 10107

**Port: -** 443

**Description: -** This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

**Business Impact: -**This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

# Stage-3

## Title: - Integrate Zscaler with Identity Providers (IdPs) such as Azure AD

### Legacy Authentication Challenges

Before implementing Zscaler-IdP integration, organizations typically face significant challenges with legacy authentication models. Traditional VPN architectures operate on an "authenticate once, trust indefinitely" principle, granting users network-level access upon successful authentication. This creates several critical issues including over-permissioned access where users can discover and attack other systems through lateral movement. VPN concentrators must be exposed to the public internet with open ports, making them visible targets for port scanning, brute-force attacks, and vulnerability exploitation. User experience suffers from traffic hair-pinning where remote traffic is routed through the data center before reaching the internet, causing latency. Hardware VPN appliances have hard capacity limits requiring manual upgrades during peak usage periods. IT staff must constantly patch, upgrade, and maintain physical VPN appliances. Most critically, legacy models lack integration with modern identity providers, forcing administrators to manage duplicate user accounts across multiple systems. These challenges create an urgent need for a modern identity-centric approach where authentication is delegated to enterprise IdPs and access is granted based on identity rather than network location.

### Zero Trust Identity Principles

The integration of Zscaler with Identity Providers is fundamentally rooted in Zero Trust Architecture principles that transform how authentication and authorization are handled. The core principle of "never trust, always verify" means every access request is fully authenticated and authorized regardless of whether the user is in the office or working remotely. "Least privilege access" ensures users are granted only the minimum access necessary to perform their job functions, enforced through identity-based policies rather than network location. "Assume breach" guides the design as if attackers are already present, requiring continuous verification of every session. "Micro-segmentation" isolates users and applications from one another to prevent lateral movement, achieved by connecting users to specific applications rather than the entire network. Identity becomes the new perimeter, replacing the traditional castle-and-moat model where the internal network was considered trusted.

Authentication must be explicit and contextual, incorporating user identity, device health, location, and behavior patterns. Authorization decisions are made dynamically based on real- time risk assessments rather than static rules. These principles directly inform how Zscaler integrates with IdPs to create a security model where identity is the primary control plane and access is granted application- by-application rather than network-by-network.

**Supported Identity Providers and Protocols**

Zscaler supports integration with a comprehensive range of identity providers through standardized protocols, ensuring flexibility for diverse enterprise environments. Microsoft Entra ID (Azure AD) integration utilizes SAML 2.0 for federated authentication and SCIM for automated user provisioning, enabling organizations to leverage Azure AD's Conditional Access policies and extensive reporting capabilities. Okta integration leverages OpenID Connect (OIDC) for modern API-friendly authentication and SCIM for lifecycle management, with pre-built connectors available through the Okta Integration Network (OIN) for streamlined setup. On-premises Active Directory integration is achieved through the Zscaler Authentication Bridge (ZAB), a lightweight connector that enables secure LDAP communication between Zscaler cloud services and internal domain controllers without requiring inbound firewall rules. The ZAB connector sits behind the firewall and initiates outbound connections to Zscaler, proxying authentication requests and synchronizing group membership information. Additional supported IdPs include Ping Identity, OneLogin, and generic SAML 2.0 providers, ensuring organizations can maintain their existing identity investments. Protocol support encompasses SAML 2.0 for browser-based SSO, OIDC for mobile and modern application scenarios, LDAP for on-premises directory integration, and SCIM 1.1/2.0 for automated user provisioning. This multi- protocol approach ensures comprehensive coverage across all access scenarios and user device types.

**Prerequisites and Licensing Requirements**

Successful implementation of Zscaler-IdP integration requires specific prerequisites and licensing to be in place before beginning the project. Zscaler Internet Access (ZIA) and/or Zscaler Private Access (ZPA) subscriptions must be active with appropriate user count licensing that includes SSO and SCIM provisioning capabilities. Administrative access to the Zscaler Admin Portal with Super Admin or appropriate delegated admin roles is required to configure authentication settings and identity provider configurations.

For cloud IdP integration, administrative access to Azure AD or Okta with permissions to create enterprise applications, configure SAML endpoints, and manage API permissions for SCIM provisioning is essential. For on-premises Active Directory integration, a Windows Server environment is required to host the Zscaler Authentication Bridge (ZAB) with outbound internet access to connect to Zscaler cloud services. Network prerequisites include firewall rules allowing outbound HTTPS (TCP 443) connections from ZAB servers to Zscaler cloud endpoints, and from user devices to Zscaler enforcement nodes. DNS resolution must be properly configured for Zscaler cloud services and internal domain controllers. Certificate management requires valid SSL certificates for SAML assertion signing if custom certificates are preferred over Zscaler-generated options

User attribute planning must identify which directory attributes (email, UPN, group memberships) will be used for policy enforcement and application segmentation.

- **Discovery and Requirements Gathering**

The discovery phase establishes the foundation for successful integration by documenting current identity infrastructure and access requirements. Begin by cataloging all internal applications currently accessed via legacy VPN, including student information systems, ERP platforms, library resources, research computing clusters, internal file servers, and administrative portals. For each application, document the protocol (HTTP/HTTPS, RDP, SSH, SMB), port numbers, IP addresses or hostnames, and user populations requiring access. Conduct user segmentation workshops to define logical groups based on job functions and access needs, such as faculty requiring access to research servers, students needing library resources, staff accessing administrative portals, IT administrators managing server infrastructure, and external collaborators requiring limited application access. Document existing identity sources including which directories (Azure AD, Okta, on-premises AD) are authoritative for each user population. Identify current authentication methods including MFA requirements, password policies, and any existing SSO implementations.

**Identity Source Architecture Planning**

Planning the identity source architecture requires careful consideration of which directories will serve as authoritative sources for different user populations. For organizations with hybrid identity infrastructure, determine whether Azure AD will be the primary authentication source with synchronization from on-premises AD via Azure AD Connect, or if direct on-premises AD integration via ZAB is preferred for specific

use cases. Document the directory synchronization topology including which user attributes are synchronized, how group memberships are managed, and the frequency of directory updates.

Plan attribute mapping between identity provider directory schemas and Zscaler user attributes, ensuring critical fields such as userPrincipalName, email, givenName, sn, and group memberships are properly mapped. For Azure AD integration, decide whether to use SAML-based authentication with optional SCIM provisioning, or OIDC for modern authentication scenarios. For Okta integration, plan the Okta Universal Directory schema and determine which profile attributes will be passed to Zscaler during authentication and provisioning. For on- premises AD integration via ZAB, document domain controller locations, network latency between sites, and high availability requirements for the ZAB connector deployment. Consider disaster recovery scenarios including failover between identity providers and offline access capabilities. Plan for phased migration of user populations from legacy authentication to Zscaler-IdP integration, starting with pilot groups and expanding to full production.

- **Application Discovery and Categorization**

Comprehensive application discovery ensures all resources requiring protected access are properly identified and categorized before policy configuration. Deploy network discovery tools or analyze firewall logs to identify all internal applications and services accessed by remote users over the past 90 days. For each discovered application, capture the fully qualified domain name (FQDN) or IP address, transport protocol (TCP/UDP), port number, and application type (web, RDP, SSH, SMB, database). Interview application owners and department heads to validate discovered applications and identify any shadow IT resources not captured in logs. Categorize applications by sensitivity level, such as public information, internal use only, confidential, and restricted, to inform policy stringency. Document application dependencies, such as applications that require access to backend databases or authentication services, to ensure proper segmentation without breaking functionality. Identify applications that share common infrastructure but require different access policies, such as multiple virtual hosts on the same web server. Create an application inventory spreadsheet with columns for application name, description, owner department, technical contact, protocol, port, destination IP/FQDN, user populations, sensitivity level, and any special access requirements. Validate application discovery findings with IT operations teams to ensure no critical systems are missed. Prioritize applications for initial ZPA configuration based on business criticality and current VPN dependency.

- **User Group Definition and Attribute Planning**

Defining user groups and planning directory attributes is essential for creating granular access policies in Zscaler. Work with HR and department leaders to identify functional roles within the organization that require distinct access profiles, such as faculty, adjunct faculty, staff, student workers, graduate researchers, undergraduate students, IT administrators, and external consultants. Document the relationship between organizational roles and directory groups, noting whether groups are synchronized from on-premises AD, managed directly in Azure AD, or maintained in Okta. Plan group nesting strategies to simplify policy management, such as creating an "All Faculty" parent group that includes nested subgroups for specific departments. Identify critical user attributes needed for policy enforcement, including department, title, location, employee type, manager, and start/end dates for temporary workers. Document multi-valued attributes such as group memberships that will be used for dynamic policy assignment.

Plan for just-in-time provisioning scenarios where users are created in Zscaler upon first authentication rather than pre-provisioned. Define attribute transformation rules if directory attributes require modification before use in Zscaler, such as converting domain\username format to user@domain format. Create a group-to-application mapping matrix that documents which user groups require access to which applications, including read-only versus read-write permissions where applicable. Validate group definitions with application owners to ensure planned access aligns with business requirements.

## Infrastructure Readiness Assessment

Assessing infrastructure readiness ensures the underlying environment can support Zscaler-IdP integration without performance or reliability issues. Evaluate network bandwidth and latency between user locations and the nearest Zscaler data centers using Zscaler's data center lookup tool, identifying any regions that may require optimized routing. Review firewall and proxy configurations to ensure outbound HTTPS traffic to Zscaler cloud endpoints (*.zscloud.net, *.zscaler.net, *.zscaler.com) is permitted without SSL inspection that could break authentication flows. Assess existing DNS infrastructure to ensure reliable resolution of Zscaler FQDNs and internal application hostnames, considering split-brain DNS if internal applications use the same DNS names internally and externally. Evaluate virtual infrastructure capacity for deploying Zscaler App Connectors, including CPU, memory, and storage requirements for the expected connection load. Review

high availability requirements and plan for deployment of multiple App Connectors across failure domains. Assess identity provider infrastructure capacity, including Azure AD authentication throughput, Okta rate limits, and on-premises domain controller capacity for handling ZAB authentication requests.

Evaluate endpoint readiness by inventorying user devices and their operating systems to ensure compatibility with Zscaler Client Connector. Test network paths from representative user locations to Zscaler cloud services using connectivity troubleshooting tools. Document any network proxies, firewalls, or security tools that may interfere with Zscaler traffic and plan for necessary exceptions.

**Azure AD Integration: SAML Configuration**

Configuring SAML-based federation between Azure AD and Zscaler establishes the trust relationship for user authentication. Begin by logging into the Azure AD portal and navigating to Enterprise Applications, then select "New Application" and search for "Zscaler" in the gallery. Select the appropriate Zscaler application based on your Zscaler cloud name (Zscaler, Zscaler2, Zscaler3, etc.) and click Create.

On the application overview page, select "Single sign-on" and choose "SAML" as the sign-on method. In the Basic SAML Configuration section, enter the Identifier and Reply URL provided by your Zscaler Admin Portal under Administration > Authentication > SAML Configuration. The Identifier typically follows the format https://<tenant>.zscloud.net/samlsp/metadata and theReplyURL is https://<tenant>.zscloud.net/samlsp/acs. Configure the User Attributes & Claims section to map Azure AD attributes to SAML assertions, ensuring the Name Identifier format is set to "Persistent" and the Source attribute is user.userprincipalname. Add additional claims as required by Zscaler, including givenname, surname, emailaddress, and group memberships. For group claims, select "Security groups" as the source and configure the group claim to include groups the user is a member of. Download the Federation Metadata XML file from Azure AD after saving the SAML configuration, as this will be uploaded to Zscaler to complete the trust configuration. Test the SAML configuration using the Azure AD test capability before proceeding to Zscaler-side configuration.

- **Azure AD Integration: SCIM Provisioning Setup**

Configuring SCIM provisioning between Azure AD and Zscaler automates user lifecycle management, ensuring accounts are created, updated, and deprovisioned automatically. From the same Zscaler enterprise application in Azure AD, select "Provisioning" from the left navigation menu and click "Get Started." Set Provisioning Mode to "Automatic" and configure the Tenant URL using the SCIM endpoint provided in your Zscaler Admin Portal under Administration > Authentication > SCIM Configuration, typically

https://<tenant>.zscloud.net/scim. Obtain the Secret Token from the same Zscaler SCIM configuration page and enter it in Azure AD. Click "Test Connection" to validate connectivity between Azure AD and Zscaler, resolving any errors before proceeding. Configure attribute mappings by expanding "Mappings" and selecting "Provision Azure Active Directory Users."

Review and modify the default attribute mappings to ensure Azure AD attributes correctly map to Zscaler user schema, paying special attention to userPrincipalName mapping to userName, email mapping to emails[type eq "work"].value, and group memberships. Configure group provisioning by expanding group mappings and ensuring Azure AD groups are properly mapped to Zscaler groups for policy enforcement. Set the provisioning scope to "Sync only assigned users and groups" for controlled rollout, then assign pilot users and groups to the application under "Users and groups." Configure provisioning settings including notification emails for failures and the provisioning interval (typically 40 minutes). Start the initial provisioning cycle by clicking "Start provisioning" and monitor the provisioning logs for any errors. Validate that test users appear in the Zscaler Admin Portal with correct attributes and group memberships before expanding scope.

## kta Integration: OIDC Application Configuration

Configuring Okta as an identity provider for Zscaler using OpenID Connect provides modern, API-friendly authentication for Zscaler services. Log into the Okta Admin Console and navigate to Applications > Applications, then click "Create App Integration." Select "OIDC - OpenID Connect" as the sign-in method and "Web Application" as the application type. Name the application "Zscaler" and click Next. Configure the Sign-in redirect URIs with the Zscaler OIDC callback URL provided in your Zscaler Admin Portal under Administration > Authentication > OIDC Configuration, typically https://<tenant>.zscloud.net/oidc/callback. Configure Sign-out redirect URIs if desired for single logout functionality. Under Assignments, control access by assigning the application to specific user groups or individual users for pilot testing. Grant API access by navigating to the "Okta API Scopes" tab and granting the following scopes: openid, profile, email, groups, and offline_access. Navigate to the "Sign On" tab and note the Client ID and Client Secret, which will be entered in Zscaler during OIDC provider configuration. Under "General Settings," configure the application's login flow, ensuring "Initiate login URI" points to your Zscaler tenant URL. Optionally configure authentication policies to enforce MFA for Zscaler access. Download the Okta metadata or note the Okta domain URL (https://<okta-domain>.okta.com) for configuration in Zscaler. Test the OIDC configuration by accessing the application's sign-on URL and verifying successful authentication with MFA if configured. Validate that user attributes including name, email, and group memberships are properly passed in the ID token for Zscaler policy enforcement.

**Okta Integration: SCIM Provisioning Configuration**

Implementing SCIM provisioning between Okta and Zscaler automates user and group synchronization for consistent identity management. In the Okta Admin Console, navigate to the Zscaler application created earlier and select the "Provisioning" tab. Click "Configure API Integration" and check "Enable API integration." Enter the SCIM connector base URL from your Zscaler Admin Portal under Administration > Authentication > SCIM Configuration, typically https://<tenant>.zscloud.net/scim. Enter the API Token from the same Zscaler configuration page and click "Test API Credentials" to validate connectivity.

Under "Provisioning to App," configure the following settings based on your requirements:

"Create Users" enabled for automatic account creation, "Update User Attributes" enabled for profile synchronization, and "Deactivate Users" enabled for automatic deprovisioning. Configure the "Push Profile" settings to ensure user attributes including firstName, lastName, email, and displayName are synchronized. Under "Push Groups," enable group push to Zscaler for policy-based access control, selecting specific groups to synchronize. Configure attribute mappings by expanding "Attribute Mappings" and reviewing how Okta profile attributes map to Zscaler user schema, making adjustments as needed for custom attributes. Set the provisioning frequency under "Settings," typically every few hours for incremental synchronization. Import existing users and groups by clicking "Import" and selecting which users to assign to the application. Test provisioning by creating a test user in Okta, assigning them to the Zscaler application, and verifying automatic creation in Zscaler. Validate deprovisioning by removing the test user assignment and confirming the user is deactivated in Zscaler. Monitor the provisioning logs for errors and adjust mappings as necessary to ensure clean data synchronization.

- **On-Premises AD Integration: ZAB Deployment**

Deploying the Zscaler Authentication Bridge (ZAB) enables secure LDAP communication between Zscaler cloud services and on-premises Active Directory without requiring inbound firewall rules. Begin by downloading the ZAB installer from the Zscaler Admin Portal under Administration > Authentication > ZAB

Configuration. Provision Windows Server virtual machines (minimum two for high availability) with the following specifications: Windows Server 2016 or later, 4 vCPUs, 8 GB RAM, 100 GB disk, and outbound internet access on TCP 443 to Zscaler cloud endpoints. Ensure the servers are domain-joined and can communicate with domain controllers on LDAP ports (389 for LDAP, 636 for LDAPS). Run the ZAB installer with administrative privileges, accepting the license agreement and selecting the installation directory.

During installation, specify the Zscaler cloud name (e.g., zscloud.net) and provide the authentication token generated in the Zscaler Admin Portal. The installer configures the ZAB service to run under Network Service account by default; for accessing domain controllers, configure the service to run under a domain service account with appropriate LDAP read permissions. After installation, verify the ZAB service is running and has established outbound connectivity to Zscaler by checking the zab.log file in the installation directory. In the Zscaler Admin Portal, navigate to Administration > Authentication > ZAB Configuration and verify the new connector appears with status "Connected." Configure LDAP directory settings by specifying domain controller FQDNs or IPs, LDAP port (389 or 636 for LDAPS), and base DN for user searches. Test LDAP connectivity by performing a test user search from the Zscaler Admin Portal. Configure high availability by deploying additional ZAB connectors; Zscaler automatically load balances across all connected connectors. Monitor connector health using the Zscaler Admin Portal dashboard and configure alerts for connector disconnections.

- **On-Premises AD Integration: Directory Connector Configuration**

Configuring the on-premises Active Directory connector in Zscaler establishes the directory synchronization and authentication settings for ZAB. In the Zscaler Admin Portal, navigate to Administration > Authentication > Directory Connectors and click "Add Directory Connector." Select "Active Directory" as the directory type and provide a descriptive name such as "Primary Campus AD." Configure the LDAP connection settings using the ZAB connector deployed earlier, specifying the domain controller FQDNs and LDAP port. For secure LDAP, select LDAPS (port 636) and ensure the domain controller certificate is trusted by the ZAB server. Specify the search base DN for user objects, such as "OU=Users,DC=campus,DC=edu," and configure search filters to include only relevant user objects, excluding disabled accounts or service accounts. Configure group search settings with appropriate base DN and filters to synchronize security groups and distribution lists needed for policy enforcement.

Set synchronization schedule options including full sync intervals (typically daily) and delta sync intervals (typically every few hours). Under attribute mapping, configure how Active Directory attributes map to

Zscaler user fields, ensuring userPrincipalName maps to username, mail maps to email, and memberOf maps to group memberships. Test the directory connection by performing a test synchronization and validating that expected users and groups appear in Zscaler. Configure authentication settings to enable LDAP authentication via ZAB for user login to Zscaler services. Set password validation options including support for expired password changes if required. Enable detailed logging for troubleshooting during initial deployment, adjusting log levels after validation.

Monitor synchronization statistics in the Zscaler Admin Portal to verify successful imports and identify any users or groups that failed to synchronize.

## Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1**, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

**Stage 2** delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

**Stage 3** The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..

Considering the future scope, **Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

**Stage 2** highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

**Stage 3** The integration of Zscaler with enterprise Identity Providers successfully establishes a unified identity framework that replaces legacy VPN architectures with a modern Zero Trust security model. This project delivers seamless Single Sign-On capabilities across all Zscaler services while enforcing consistent security policies including Multi-Factor Authentication and conditional access based on user identity and context. Automated user provisioning via SCIM significantly reduces administrative overhead by eliminating manual account management and ensuring immediate deprovisioning when users leave the organization. The implementation of identity-based micro-segmentation effectively prevents lateral movement by connecting users to specific applications rather than the entire network. By leveraging industry-standard protocols including SAML, OIDC, and LDAP, the integration preserves existing investments in identity infrastructure while enabling cloud-delivered security. User experience is transformed through frictionless authentication and reduced latency from Zscaler's global cloud footprint. Security posture is enhanced through real-time policy enforcement and comprehensive audit logging of all access attempts. This integration lays a robust foundation for future identity-centric security initiatives aligned with Zero Trust principles

## Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

## Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

## Future scope of SOC / SEIM:-

The successful integration of Zscaler with enterprise Identity Providers opens numerous avenues for future enhancement and expansion of the security ecosystem. Integration with additional Identity Providers such as Ping Identity, OneLogin, and Google Workspace can be implemented to support diverse user populations including affiliates, contractors, and research collaborators from partner institutions. Advanced conditional access policies leveraging real-time risk scores from integrated threat intelligence platforms like MISP can enable dynamic, context-aware authentication decisions that adapt to changing threat landscapes.

Expansion of device posture checks to include deeper integration with endpoint detection and response (EDR) tools such as CrowdStrike, SentinelOne, and Microsoft Defender for Endpoint will enable more granular access decisions based on real-time device health indicators. Implementation of privileged access management (PAM) workflows for temporary administrative access can provide just-in-time elevation with automated approval workflows and session recording for compliance. Integration with identity governance and administration (IGA) platforms like SailPoint or Saviynt can enable automated access certification campaigns and policy violation remediation. Expansion of Zscaler Internet Access (ZIA) policies to include more sophisticated data loss prevention rules based on user attributes and sensitive content detection will protect against data exfiltration. Integration with security orchestration, automation, and response (SOAR) platforms can enable automated incident response workflows triggered by Zscaler authentication anomalies. Deployment of Zscaler for branch locations with SD-WAN integration can extend identity-based policies to all network edges. Implementation of user behavior analytics (UBA) to detect anomalous access patterns and trigger adaptive authentication responses will enhance threat detection capabilities. Integration with HR systems for authoritative user lifecycle events can further automate joiner, mover, leaver processes without manual intervention.

Expansion to support Internet of Things (IoT) and operational technology (OT) device authentication through certificate-based identity will extend Zero Trust principles to non-user entities. Continuous policy optimization through machine learning analysis of access patterns will ensure policies remain effective as organizational needs evolve.

## Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

## Tools explored:

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite